프라이버시가드

# LLM 보안 프록시
# MVP 범위 및 요구사항

공공기관·사내망에서 개인정보 유출과 프롬프트 인젝션을 방지하는 사용 흐름

01 · SCENARIO

# 핵심 사용 시나리오



**사용자가 LLM을 활용하는 과정에서 보안 프록시가 입력과 출력을 검사한다.**

### 사용자

- 동사무소·행정복지센터 및 사내망 직원

### 사용 목적

- 민원 내용 요약 등 업무에 생성형 AI를 안전하게 활용

### 주요 위험

- 개인정보 유출 및 프롬프트 인젝션 공격

### 시나리오 예시

직원이 민원 내용을 요약하려고 LLM에 입력한다. 입력에 전화번호 등 개인정보가 포함되어 있거나, 시스템 지시를 무시하도록 유도하는 악성 프롬프트가 포함되어 있을 수 있다.

**목표: LLM 사용을 막는 것이 아니라, 보안 계층을 통해 안전하게 사용한다.**

# Must 기능 (필수 요구사항)



## 가치 검증에 반드시 필요한 핵심 보안 프록시 기능 목록

### 1. 입력 사전 검사 & 차단

- PII는 패턴 탐지, 인젝션은 규칙·경량 분류로 보완
- 악성 프롬프트 인젝션 시도 탐지 시 **BLOCK**
- 차단 시 LLM 호출 없이 사용자 경고 응답 반환

### 2. 개인정보 자동 마스킹 (MASK)

- 식별된 개인정보를 마스킹 패턴으로 치환
- 탐지한 PII를 마스킹한 입력을 업스트림 전달
- 미탐지 개인정보의 유출 위험은 남음

### 3. SSE 응답 버퍼링·출력 검증

- LLM 응답 전체를 버퍼링한 뒤 SSE로 반환
- 생성 완료 후 Validator 검사, 실시간 토큰 검증 아님

### 4. 감사 로그 무결성 검증

- 원문 미저장, 판정·사유 코드 등 메타데이터 기록
- ML-DSA 교체 가능한 감사 로그 서명 인터페이스와 Mock signer 기반 검증 구조

# Should 기능 (우선 구현)



**제품 사용 및 운영에 중요하나 대체 가능 또는 2차 구현 가능한 기능**

### 대시보드 시각화

- 구현: 관리자 화면에서 차단·마스킹 집계 조회
- 실시간 갱신·추가 그래프는 개선 검토

### WARN 정책 지원

- 구현: 사전 분석 WARN 시 확인·취소 제공
- 확인 후에도 서버 재검사·마스킹·BLOCK 유지

### 조직별 정책 설정 (향후)

- 미구현: 부서/그룹별 탐지 민감도 차등 적용
- 미구현: 관리자 커스텀 키워드 추가/삭제

### 범위 명확화

우선순위와 구현 상태는 구분한다. 관리자 조회와 WARN 확인은 구현됐으며, 조직별 정책 편집은 향후 확장 범위다.

# 비기능 요구사항



성능 목표와 현재 구현을 구분하며 목표의 타당성을 멘토링에서 확인한다.

### 응답 지연 최소화 (Latency)

- 목표 후보: 검사 오버헤드 **평균 50ms 이내** (미검증)
- 검사 범위·환경·부하 조건 합의 후 측정

### 개인정보 보호 (Privacy)

- 감사 로그에 **입력·응답·개인정보 원문 미저장**
- 메타데이터 및 차단 사유 코드만 로그 기록

### 시스템 안정성 (Reliability)

- 목표 후보: 동시 요청 100건 세션 유지 (미검증)
- LLM 장애 시 프록시 단 예외 처리 응답 반환

### 감사 무결성 (Integrity)

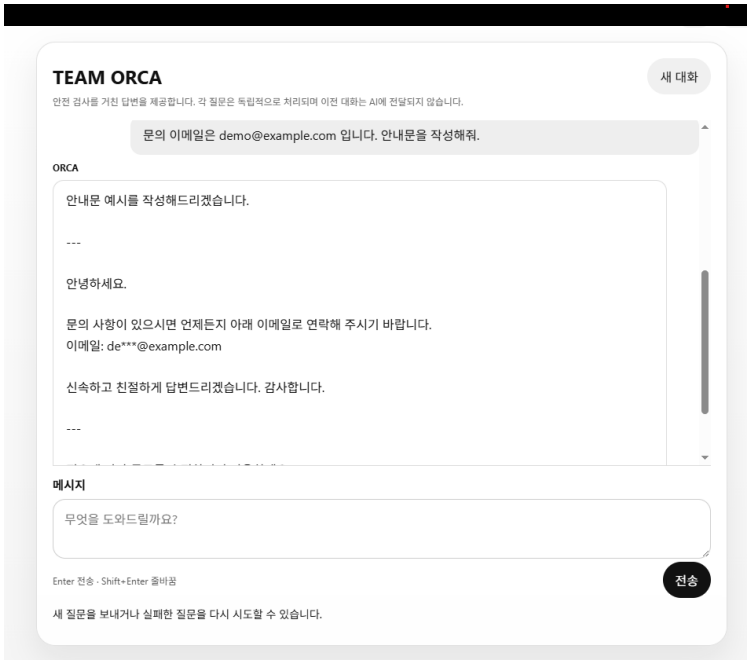
- 레코드별 해시·Mock 서명 생성, 체인 미구현
- 검증 실행 시 변조 확인, 실시간 감시 아님

# 현재 UI 화면



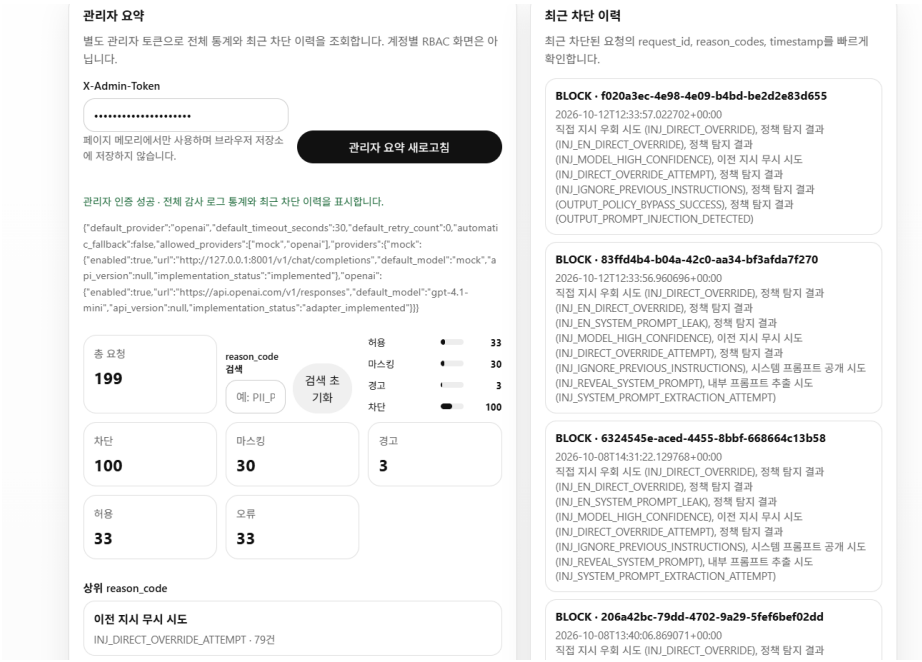
**사용자와 관리자의 화면을 분리해 안전한 답변과 처리 근거를 제공한다.**

## 사용자 채팅 /app




예시 이메일을 가린 응답을 사용자 화면에 표시

## 관리자 요약 /admin




별도 관리자 인증으로 전체 통계·최근 차단 이력 조회

사용자 제공 2026-10-13 캡처. 실제 Provider 호출은 별도 로그 확인 필요.
화면 집계는 탐지 성능 평가가 아니며, TEAM ORCA는 기존 UI 표기다.

# 기능별 완료조건



기능이 실제로 동작하는지 확인할 수 있는 관찰 가능한 기준으로 작성한다.

### 개인정보 마스킹

전화번호가 포함된 입력에서 마스킹된 값이 전달되는가?

### 인젝션 차단

차단 시 LLM 미호출 확인 `upstream_call: false`

### 정상 요청 처리

정상 입력이 LLM에 전달되고 응답이 반환되는가?

### 감사 로그

원문 미저장·처리 사유 기록 확인 `reason_code`

### 완료 기준·멘토 확인 질문

**네 가지 테스트 결과를 화면 또는 로그로 확인하고 증빙을 남긴다.**
**멘토 확인: MVP 범위의 적절성, 성능 목표의 타당성, 다음 개발 우선순위**